

Forgot Password – Program Logic (OBE Tracking System)

Module 1: Forgot Password Request (Send Reset Link)

- Receive email from the user.
- Check if the email exists in the system.
- If user exists:
 - Generate a unique reset token.
 - Store token with user reference, creation time, and unused status.
 - Create a reset password link using the token.
 - Send the reset link to the user via email.
- If user does not exist:
 - Do not reveal anything (for security).
- Return a success message to the user.

Module 2: Reset Password Using Token

- Receive token and new password from the user.
- Find the token in the database and ensure it is unused.
- If token does not exist: return invalid token error.
- Check if the token has expired.
- If expired: return token expired error.
- Validate the new password (length, strength).
- Fetch the user linked to the token.
- Encrypt and save the new password.
- Mark the token as used.
- Invalidate old login sessions or JWT tokens.
- Return password reset success response.

Token Expiry Logic

- Each token has a creation time.
- Token validity duration is 15 minutes.
- If current time exceeds creation time + 15 minutes, token is expired.

Security Rules Followed

- Token is unique and random.
- Token can be used only once.
- Token expires after a fixed time.

- Same response is returned for valid and invalid emails.
- Password is never sent through email.

Summary

The forgot password functionality works by generating a temporary secure token, sending it to the user via email, validating the token, and allowing the user to reset their password only after successful verification.